

CDN Cache Misconfiguration Vulnerability on i-tutor

Found on Subdomain:

<https://learn.aakashitutor.com/tests/collection/series?res=Active&tcid=1095283799>

Reporter Name: Abhigyan Srivastav

JEE Aspirant at Aakash Ayodhya

PSID: 00003086242

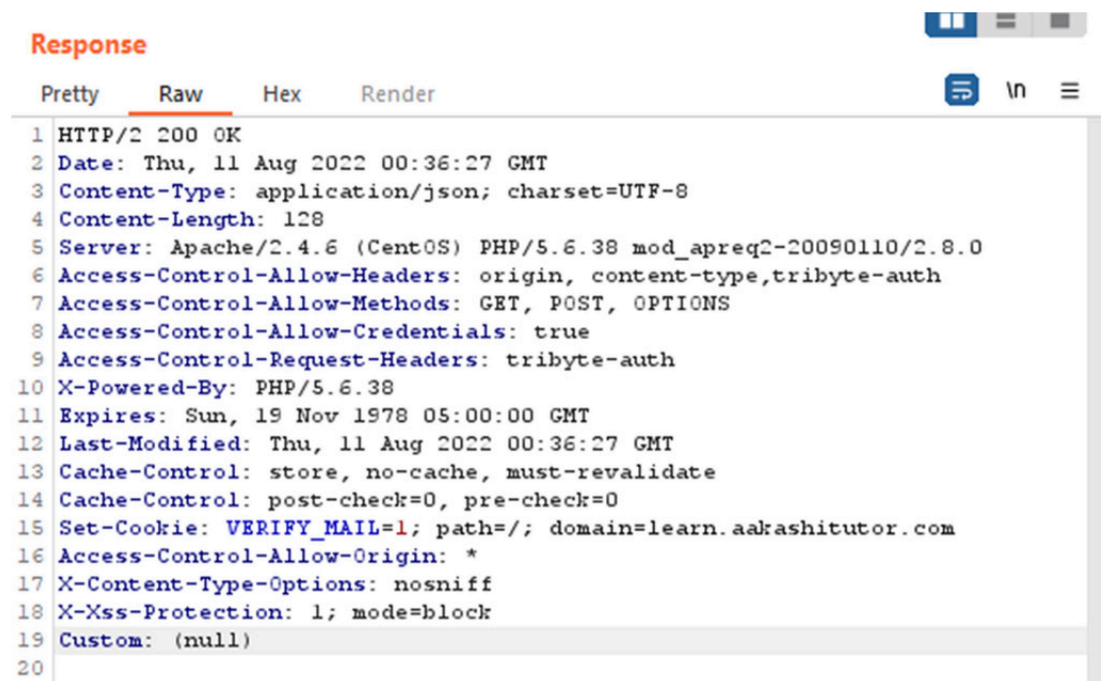
Batch: SR_01

Defect Detected Date: 09-08-2022

Cache Misconfiguration Vulnerability was found on i-Tutor's Quiz section

When a student gives quiz or a test, your CDN server sends local cache files to the client but the problem is In this misconfiguration, some of your credential cache also loads on clients' system; even you have set cache directives.

(NOTE: THIS ISN'T A BUG BUT A MISCONFIGURATION, SOMETHING LIKE WEB_CACHE_DECEPTION)



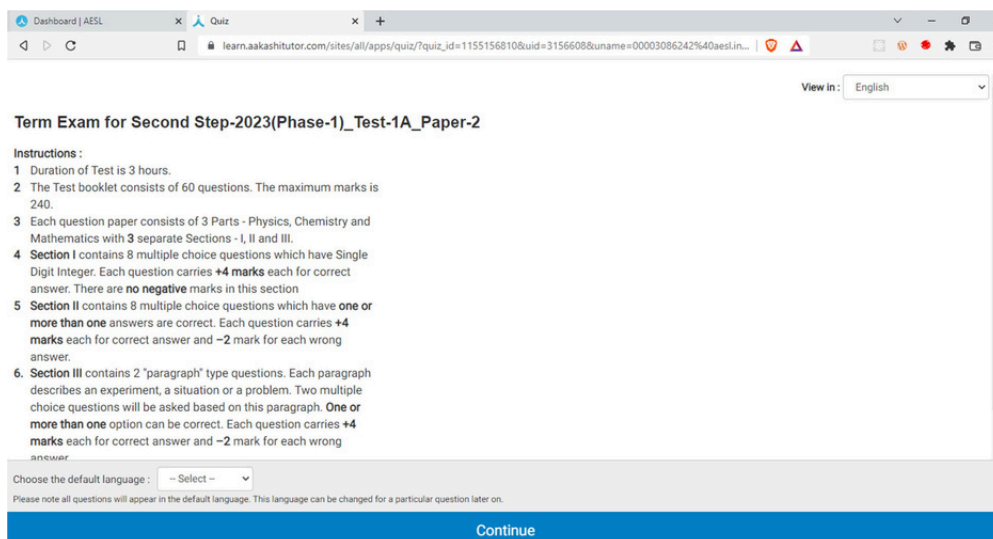
```
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Date: Thu, 11 Aug 2022 00:36:27 GMT
3 Content-Type: application/json; charset=UTF-8
4 Content-Length: 128
5 Server: Apache/2.4.6 (CentOS) PHP/5.6.38 mod_apreq2-20090110/2.8.0
6 Access-Control-Allow-Headers: origin, content-type, tribyte-auth
7 Access-Control-Allow-Methods: GET, POST, OPTIONS
8 Access-Control-Allow-Credentials: true
9 Access-Control-Request-Headers: tribyte-auth
10 X-Powered-By: PHP/5.6.38
11 Expires: Sun, 19 Nov 1978 05:00:00 GMT
12 Last-Modified: Thu, 11 Aug 2022 00:36:27 GMT
13 Cache-Control: store, no-cache, must-revalidate
14 Cache-Control: post-check=0, pre-check=0
15 Set-Cookie: VERIFY_MAIL=1; path=/; domain=learn.aakashitutor.com
16 Access-Control-Allow-Origin: *
17 X-Content-Type-Options: nosniff
18 X-Xss-Protection: 1; mode=block
19 Custom: (null)
20
```

(Burpsuite-Scan)

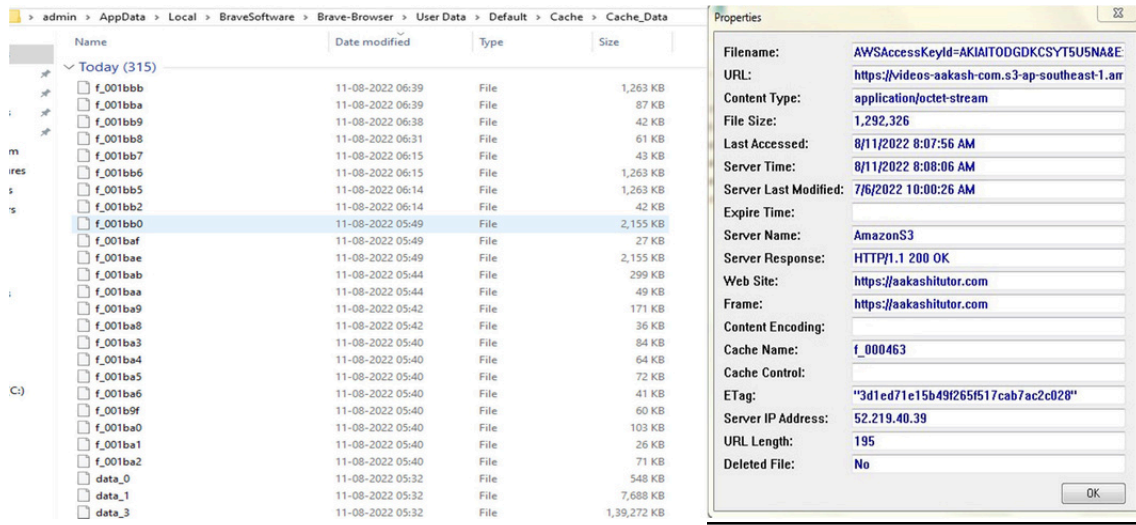
Steps to Reproduce:

Introduction: Due to this misconfiguration, answer keys of every exam except (Practice tests) can be accessed through the loaded cache files without opening the quiz.

- Step-1) Loading the quiz window:



□ Step-2) Opening the browser cache data:



The screenshot displays the Brave Browser's cache data interface. The left pane shows a list of cache files under 'Today (315)'. The right pane shows the 'Properties' for a selected file.

Name	Date modified	Type	Size
f_001bbb	11-08-2022 06:39	File	1,263 KB
f_001bba	11-08-2022 06:39	File	87 KB
f_001bb9	11-08-2022 06:38	File	42 KB
f_001bb8	11-08-2022 06:31	File	61 KB
f_001bb7	11-08-2022 06:15	File	43 KB
f_001bb6	11-08-2022 06:15	File	1,263 KB
f_001bb5	11-08-2022 06:14	File	1,263 KB
f_001bb2	11-08-2022 06:14	File	42 KB
f_001bb0	11-08-2022 05:49	File	2,155 KB
f_001baf	11-08-2022 05:49	File	27 KB
f_001bae	11-08-2022 05:49	File	2,155 KB
f_001bab	11-08-2022 05:44	File	299 KB
f_001baa	11-08-2022 05:44	File	49 KB
f_001ba9	11-08-2022 05:42	File	171 KB
f_001ba8	11-08-2022 05:42	File	36 KB
f_001ba3	11-08-2022 05:40	File	84 KB
f_001ba4	11-08-2022 05:40	File	64 KB
f_001ba5	11-08-2022 05:40	File	72 KB
f_001ba6	11-08-2022 05:40	File	41 KB
f_001ba9f	11-08-2022 05:40	File	60 KB
f_001ba0	11-08-2022 05:40	File	103 KB
f_001ba1	11-08-2022 05:40	File	26 KB
f_001ba2	11-08-2022 05:40	File	71 KB
data_0	11-08-2022 05:32	File	548 KB
data_1	11-08-2022 05:32	File	7,688 KB
data_3	11-08-2022 05:32	File	1,39,272 KB

Properties

Filename: AWSAccessKeyId=AKIAITODGDKCSYT5U5NA&E
URL: https://videos-aakash-com.s3-ap-southeast-1.a...
Content Type: application/octet-stream
File Size: 1,292,326
Last Accessed: 8/11/2022 8:07:56 AM
Server Time: 8/11/2022 8:08:06 AM
Server Last Modified: 7/6/2022 10:00:26 AM
Expire Time:
Server Name: AmazonS3
Server Response: HTTP/1.1 200 OK
Web Site: https://aakashitutor.com
Frame: https://aakashitutor.com
Content Encoding:
Cache Name: f_000463
Cache Control:
ETag: "3d1ed71e15b49f265f517cab7ac2c028"
Server IP Address: 52.219.40.39
URL Length: 195
Deleted File: No

□ Step-3) Accessing the cache data files:

QUICK FILTER									
f_001bb		Find one string	Search all columns	Show only items match the:	Case Sensitive				
Filename	URL	Content Type	File Size	Last Accessed	Server Time	Server Last Modified	Expire Time	Server Name	Server Resp
AWSAccessKeyl...	https://videos-aakash-com.s3-ap-southeast-1.amazonaws.co...	application/octe...	2,206,636	11-08-2022 05:49:20	11-08-2022 05:49:19	17-07-2022 08:01:36		AmazonS3	HTTP/1.1 20
AWSAccessKeyl...	https://videos-aakash-com.s3-ap-southeast-1.amazonaws.co...	application/octe...	1,292,326	11-08-2022 06:14:58	11-08-2022 06:14:59	06-07-2022 10:00:26		AmazonS3	HTTP/1.1 20
AWSAccessKeyl...	https://videos-aakash-com.s3-ap-southeast-1.amazonaws.co...	application/octe...	1,292,326	11-08-2022 06:15:08	11-08-2022 06:15:09	06-07-2022 10:00:26		AmazonS3	HTTP/1.1 20
AWSAccessKeyl...	https://videos-aakash-com.s3-ap-southeast-1.amazonaws.co...	application/octe...	1,292,326	11-08-2022 06:39:10	11-08-2022 06:39:11	06-07-2022 10:00:26		AmazonS3	HTTP/1.1 20
catalog.json	https://static.ads.brave.com/v9/catalog	application/json	62,417	11-08-2022 06:31:46	11-08-2022 06:31:02				HTTP/1.1 20
nid=1155156810...	https://learn.aakashitutor.com/api/getquizfromid?nid=115515...	application/json	88,353	11-08-2022 06:39:08	11-08-2022 06:39:09	11-08-2022 06:39:09		Apache/2.4.6 (Cent...	HTTP/1.1 20
res=Active&cid...	https://learn.aakashitutor.com/tests/collection/series?res=Act...	text/html	42,442	11-08-2022 06:14:51	11-08-2022 06:14:52	11-08-2022 06:14:51		Apache/2.4.6 (Cent...	HTTP/1.1 20
res=Active&cid...	https://learn.aakashitutor.com/tests/collection/series?res=Act...	text/html	42,418	11-08-2022 06:38:29	11-08-2022 06:38:31	11-08-2022 06:38:29		Apache/2.4.6 (Cent...	HTTP/1.1 20
res=Active&cid...	https://learn.aakashitutor.com/tests/collection/series?res=Act...	text/html	43,911	11-08-2022 06:15:57	11-08-2022 06:15:58	11-08-2022 06:15:57		Apache/2.4.6 (Cent...	HTTP/1.1 20

- Step-4) Opening the file & accessing the key (can be decoded to base64):

["title": "A dipole having dipole moment is placed at origin of coordinate system as shown in figure. If electric field
rc="data:image/png;base64,iVBORw0KGgoAAAANSUhEUgAAAEsAAAAAtCAYAAADm45atAAAAAXNSR0ICQV

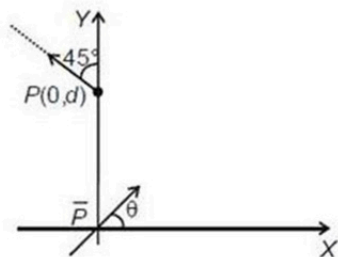
(Que-1 [Phy])

own in figure. If electric field at point $P(0, d)$ is along dotted line shown in figure, then angle is . Find the value c
ADm45atAAAAAXNSR0ICQM9xQAAAAIwSFzAAAOxAAADsQBISsOGwAAABl0RVh0U29mdHdhcmUATWljb
id the value of $\langle j \cdot n \rangle$.<Vp> <p>Answer (5)</p> <p><img align="absmiddle" wid

(Ans-1)

Question : 1

A dipole having dipole moment $\vec{p}$ is placed at origin of coordinate system as shown in figure. If electric field at point $P(0, d)$ is along dotted line shown in figure, then angle θ is $\sin^{-1}\left(\frac{1}{\sqrt{n}}\right)$. Find the value of n .



Options:

Correct Answer

5 ✓

User Answer

5 ✓

(Proof)

For the network shown, switches S_1 and S_3 are closed and switch S_2 is open. When the capacitors are fully charged, S_3 is opened and S_2 is simultaneously closed. Charge flown through switch S_2 (in μC) is Q . Value of $\frac{Q}{5}$ is

(Que-2 [Phy])

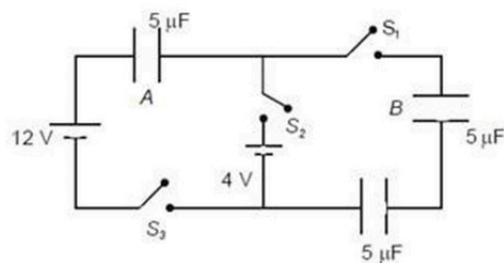
Answer (2)

(Ans-2)

Question : 2

For the network shown, switches S_1 and S_3 are closed and switch S_2 is open. When the capacitors are fully charged, S_3 is opened and S_2 is simultaneously closed.

Charge flown through switch S_2 (in μC) is Q . Value of $\frac{Q}{5}$ is



Options:

Correct Answer

User Answer

2 ✓



(Proof)

NOTE: Even the test not got opened, answer key was accessed...

TERM EXAM FOR SECOND STEP-2023(PHASE-1) - MISSED

 **TERM EXAM FOR SECOND STEP-2023(PHASE-1)**

Term Exam for Second Step-2023(Phase-1)_Test-1A_Paper-2
60 Question | 180 Minutes
Exam Date **06/07/2022**

[Start a Test](#)

IMPACT

- 1) DESERVED SEATs CAN BE TAKEN BY AN ATTACKER
- 2) ATTACKER CAN MAKE LAKHS...
- 3) CONFIDENTIAL DATA CAN BE LEAKED

SOLUTION

I don't have any permanent solution for this misconfiguration but I'm trying to get one... Will inform you about the solution & more bugs.

TOOLS USED:

- Burp suite
- Website Sniffer